

Máster Universitario de Ciberseguridad

Metodología de Evaluación de riesgos de ciberseguridad para entornos Cloud

Profesor tutor: Marc Fernandez Antolín

Alumnos

- Carlos Oberreuter



Universidad
Internacional
de Valencia

Introducción y Objetivos

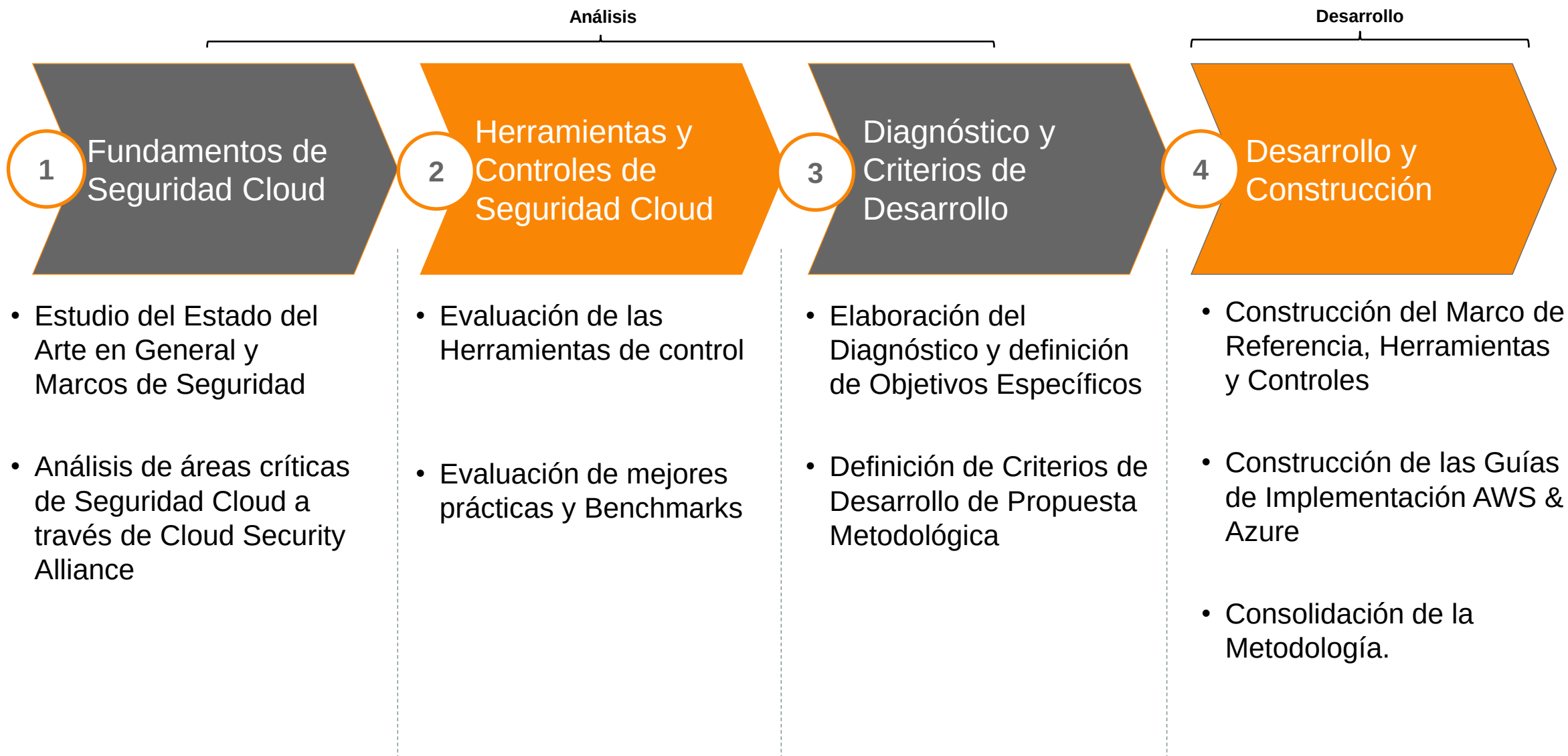
Desarrollo de una "Metodología de Evaluación de Riesgos de Ciberseguridad para entornos Cloud" a través de un análisis de las prácticas de la industria y los marcos de referencia

Nuestro Trabajo de Fin de Master se centra en el entendimiento de las áreas críticas de seguridad que deben considerarse en la implementación de soluciones en la nube tanto por parte de los consumidores y proveedores de servicios Cloud, **mediante el análisis de las herramientas y los controles de seguridad** recomendados por la industria.

Como alcance, el estudio tiene como objetivo la evaluación de los dominios de control y una guía de recomendaciones en las tecnologías que ofrecen los proveedores de servicios: Microsoft Azure y AWS Amazon.

Enfoque y Plan de Trabajo

Actividades
Claves



FUNDAMENTOS DE SEGURIDAD

Análisis de las Áreas Críticas

El objetivo de esta etapa es un análisis y entendimiento de las áreas críticas de Seguridad Cloud, según la Cloud Security Alliance y a partir de sus guías



FUNDAMENTOS DE SEGURIDAD

Áreas Críticas y Conclusiones Claves

- 1** Conceptos y Arquitecturas de Computación en la Nube
Este dominio revisa principalmente la información para entender los modelos en la nube, enfatizando una comprensión completa del modelo lógico y la capa de la metaestructura.
- 2** Gobierno y Gestión de Riesgo Corporativo
Este dominio revisa las recomendaciones de la Seguridad en la Nube con respecto a los cambios de Gobierno y gestión de riesgos.
- 3** Aspectos Legales, Contratos y Descubrimiento Electrónico
Este dominio analiza cuestiones legales relacionadas con los servicios en la nube, la importancia de la diligencia interna y externa y aspectos del descubrimiento electrónico y la admisibilidad del almacenamiento electrónico (ESI).
- 4** Cumplimiento y gestión de auditoría
Este dominio analiza la gestión del cumplimiento y los auditores en un entorno de nube, centrándose en el papel de los auditores independientes y la aplicación de estos conceptos en diversas situaciones.
- 5** Gobierno de la Información
Este dominio aborda la importancia del gobierno y los procesos de la información, examinando el ciclo de seguridad de los datos para identificar puntos de control para diversas actividades y ubicaciones, desde el almacenamiento de datos hasta el acceso a los dispositivos.

FUNDAMENTOS DE SEGURIDAD

Áreas Críticas y Conclusiones Claves

- 6** **Plano de Administración y Continuidad del Negocio**

Este dominio analiza la importancia en el acceso y seguridad de las consolas de administración de la plataforma de nube, la gestión de la continuidad del negocio, la recuperación ante desastres y la planificación adecuada para cumplir con los requisitos comerciales.
- 7** **Seguridad de la Infraestructura**

Este dominio cubre la Seguridad del plano de Administración, Continuidad del negocio y recuperación ante desastres en la nube.
- 8** **Virtualización y Contenedores**

Este dominio amplía la cobertura sobre virtualización, redes y almacenamiento de información, incluida información adicional sobre las responsabilidades de seguridad divididas entre proveedores y clientes.
- 9** **Respuesta a Incidentes**

Este dominio se centra en las particularidades de responder a incidentes en la nube y ofrece orientación sobre cómo ajustar los procesos de respuesta en consecuencia. Se basa en el ciclo de vida de gestión de incidentes del NIST.
- 10** **Seguridad de Aplicaciones**

Este dominio examina la seguridad de las aplicaciones en un entorno de nube, centrándose en nuevos enfoques para la arquitectura y el diseño.

FUNDAMENTOS DE SEGURIDAD

Áreas Críticas y Conclusiones Claves



- | | | |
|----|--|---|
| 11 | Seguridad de Datos y Encriptación | Este dominio examina los controles de seguridad como herramientas esenciales para llevar a cabo el Gobierno de la información y los datos, tomando en cuenta la gestión del riesgo desde un punto de vista empresarial. |
| 12 | Gestión de Identidades, Derechos y Accesos | Este dominio analiza los cambios y desafíos en la gestión de identidades y el control de acceso en entornos de computación en la nube, enfatizando la importancia de la federación de identidades para administrar diversos proveedores y servicios. |
| 13 | Seguridad como Servicio | Este dominio analiza el concepto de seguridad como servicio (SecaaS) y sus características. Se centra en cómo se pueden utilizar los servicios en la nube, como SaaS y la plataforma como servicio (PaaS), para proteger los activos implementados en ambos entornos. |
| 14 | Tecnologías Relacionadas | Este dominio examina tecnologías fundamentales que se encuentran frecuentemente en entornos de nube, las cuales dependen de recursos escalables que pueden aumentar o disminuir según la demanda. |

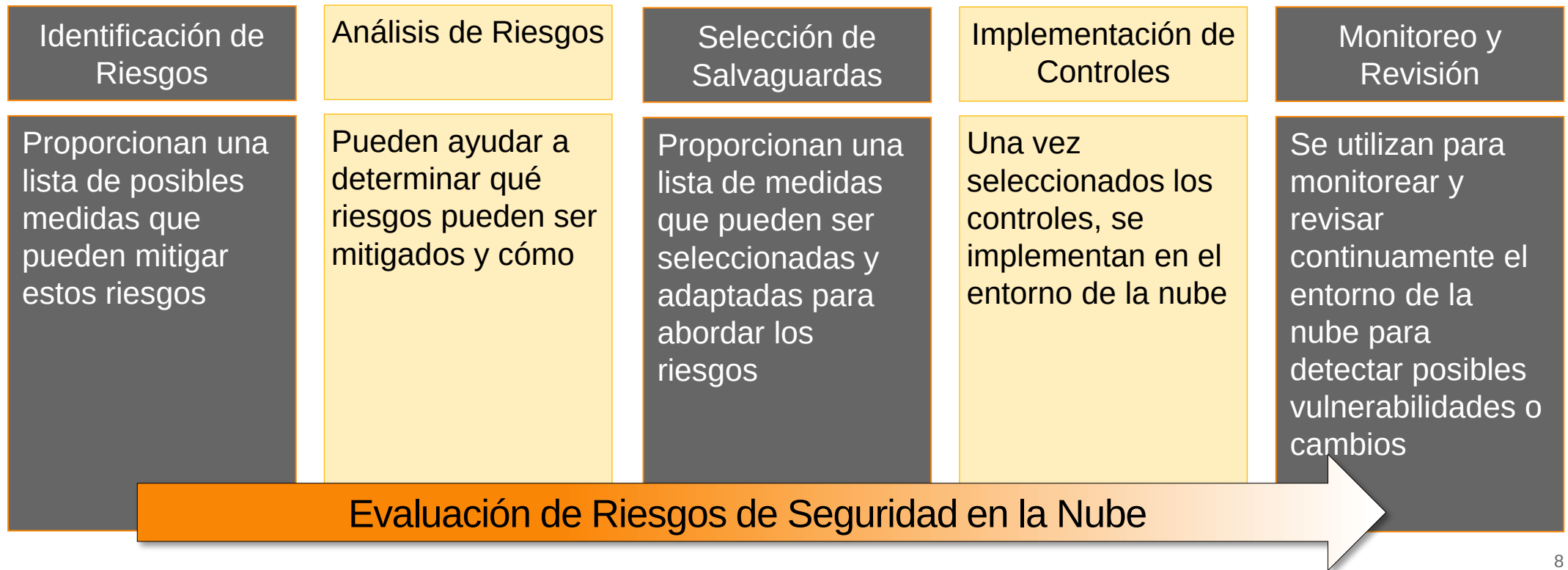
En esta etapa podemos concluir que a partir del estudio realizado de las áreas críticas CSA, se establecen las directrices fundamentales y Guía de Recomendaciones Claves de CSA para el proceso de desarrollo.

HERRAMIENTAS Y CONTROLES DE SEGURIDAD CLOUD



Los controles de seguridad son herramientas esenciales que se utilizan en las evaluaciones de riesgos de seguridad en la nube para mitigar los riesgos y garantizar la seguridad de los datos y los sistemas en entornos de nube

Se utilizan en varias etapas del proceso



HERRAMIENTAS Y CONTROLES DE SEGURIDAD

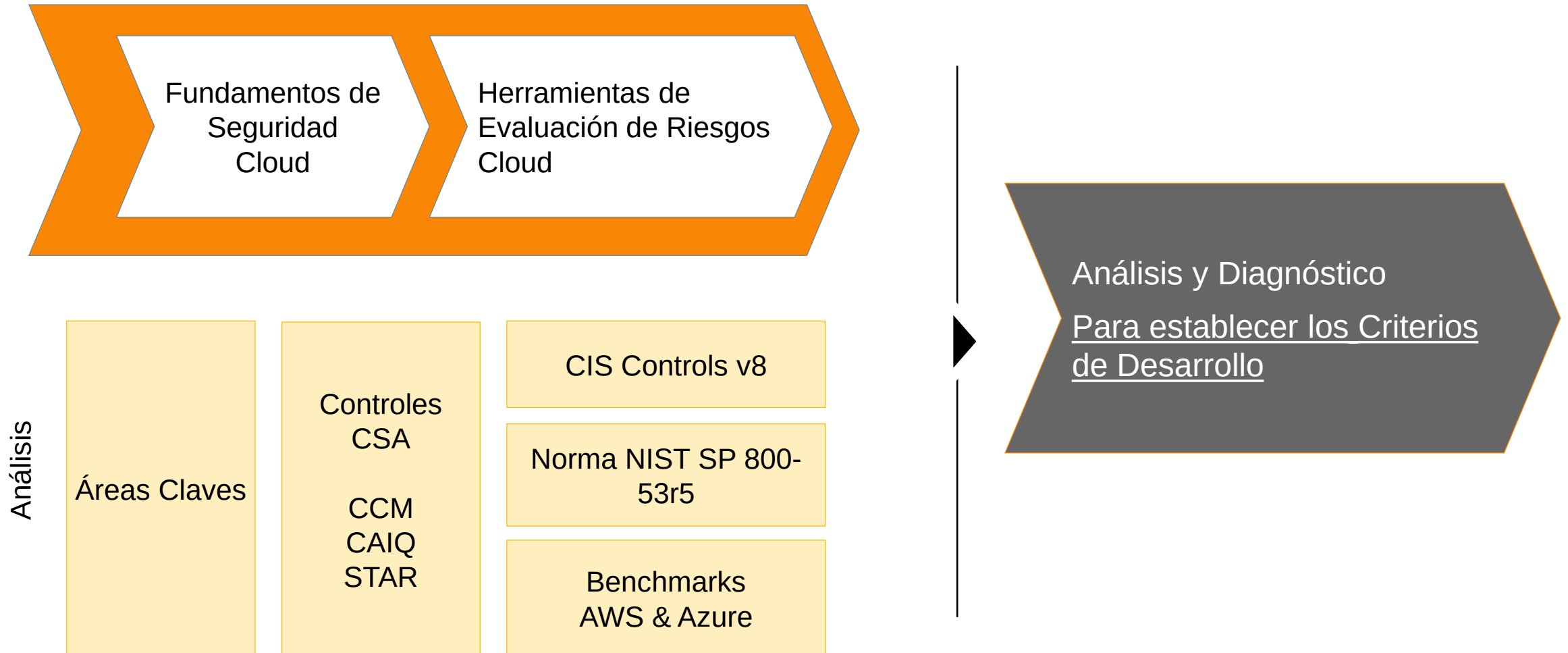
Evaluación



Matriz de controles CCM	Proporciona los principios, controles y criterios fundamentales de control de seguridad en la implementación, evaluación y gestión los riesgos de seguridad asociados con los servicios en la nube. Incluye 197 controles objetivos en 17 dominios la Guía CCMv4.
El Cuestionario de la Iniciativa de Evaluación de Consenso (CAIQ)	CAIQ, es el cuestionario de preguntas orientado a los proveedores de servicios de nube y que se basa en las mejores prácticas que se encuentran en CCM. Se utiliza mejor para documentación y auditoría, poniendo foco en la transparencia.
El Registro STAR Azure & AWS	Es la referencia para realizar una inspección de los controles de seguridad de los proveedores, de acuerdo con los niveles existentes: Nivel 1 & Nivel 2 (Certificación de Terceros).
Norma NIST SP 800-53r5	Proporciona un conjunto de controles de seguridad que las organizaciones puedan usar para proteger sus sistemas y datos. Incluye 20 dominios o familias de controles de seguridad y privacidad, y algo más de 1000 controles
CIS Controls v8, para Azure y AWS	La guía de "CIS Controls Cloud Companion Guide" v8 del "Center for Internet Security" CIS, ofrece recomendaciones específicas para la implementación de los Controles CIS en entornos de computación en la nube. se incorporan 20 dominios y 153 controles .
Benchmarks	Son esfuerzos globales de ciberseguridad diseñados para proteger los sistemas de las amenazas. Proporcionan pasos detallados para establecer controles de seguridad en las implementaciones en la nube y se centran en ajustes técnicos para mantener o aumentar la seguridad de la tecnología.

DIAGNÓSTICO Y CRITERIOS DE DESARROLLO

Diagnóstico



HERRAMIENTAS Y CONTROLES DE SEGURIDAD

Análisis y Diagnóstico para establecer los Criterios de Desarrollo

Herramientas	Diagnóstico	Objetivos / Criterios para el Desarrollo
Áreas Claves CSA	Son los Fundamentos de Seguridad y que se deben considerar como parte de la preparación, entendimiento de los aspectos básicos del proveedor y consumidor de los servicios de Nube para cualquier Evaluación de Riesgo de Cloud.	Considerar las áreas claves de CSA y las Herramientas de Control existentes CSA como directrices que permiten evaluar los riesgos y postura de ciberseguridad basado en las mejores prácticas a través de los Dominios de Control.
Dominios en los Controles de Seguridad Cloud	En el análisis detallado comparativo de los dominios de Control de CCM (17), NIST (20) y CIS (18), se determinó que cada marco tiene sus propios dominios, lo que se ha identificado como una <u>oportunidad para el desarrollo de la nueva metodología.</u>	Agrupar, Estandarizar y <u>simplificar los Dominios de Control</u> para agrupar los diferentes aspectos de seguridad identificados en categorías coherentes y fáciles de entender.
Herramientas, Controles de Seguridad Cloud y Benchmarks	- Los marcos de control de CIS y NIST han sido adoptados por AWS y Azure quienes proporcionan recursos para implementar los controles en su documentación - Benchmarks CIS Controls v8 para AWS y Azure proporcionan un punto de referencia común. El “Azure Security Benchmark” cubre CIS Controls v8, NIST SP800-53 r4, pero excluye los controles CCM de CSA. AWS ofrece directrices operacionales para las prácticas CIS y NIST de manera independiente. - La Matriz de Controles de CSA CCM contiene un mapa de relación entre los controles dentro los cuales está documentado la relación entre CCM, CIS y NIST.	Establecer una base de Controles Críticos CIS, NIST <u>y que incorporen los controles de CSA CCM Aplicables en AWS y Azure</u>, desarrollando un nuevo benchmark consistente con los Fundamentos de Seguridad de CSA para la Evaluación de Riesgo de Cloud.

HERRAMIENTAS Y CONTROLES DE SEGURIDAD

Análisis y Diagnóstico para establecer los Criterios de Desarrollo

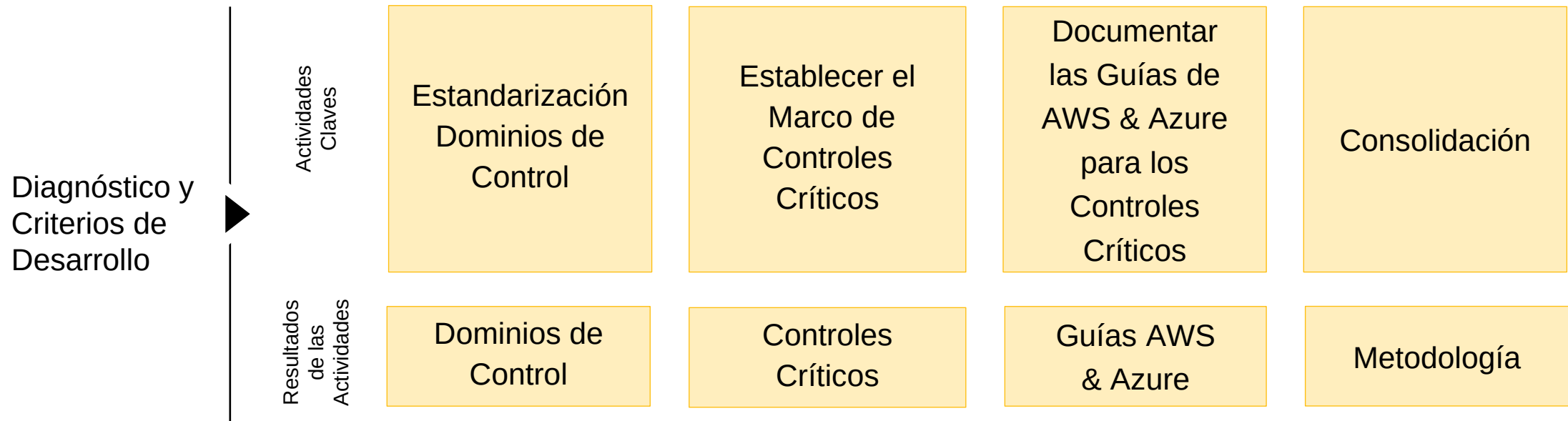
Herramientas	Diagnóstico	Objetivos / Criterios para el Desarrollo
Tecnologías AWS & Azure	- La Matriz de Controles CCM como documento agnóstico a los proveedores de nube <u>no contiene una guía de navegación</u> o configuración técnica de implementación en AWS y Azure desde la perspectiva del rol de consumidor de servicios de nube en este documento. - Por otro lado, la referencia a CSA existente en documentación pública de estos proveedores, hace mención únicamente a las certificaciones obtenidas con CSA desde la posición de proveedor de Nube, lo cual se identifica como una <u>oportunidad para el desarrollo de la nueva metodología desde la perspectiva de consumidor de servicios de Nube.</u>	Documentar las Guías para los Controles Críticos CISv8, NIST 800 53 r5 y CSA CCM Aplicables en AWS y Azure.

En esta etapa podemos concluir que definimos los criterios de desarrollo para la Construcción de la Propuesta de la Metodología

DESARROLLO Y CONSTRUCCIÓN

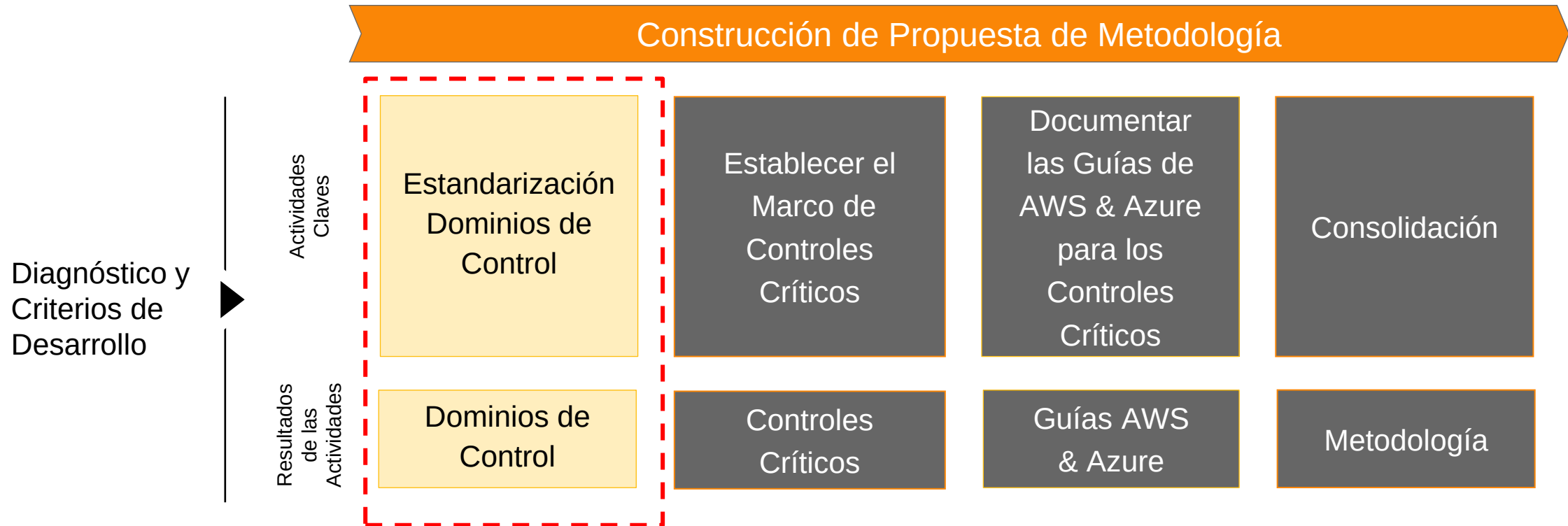
Objetivo: En esta etapa, tomando en cuenta los objetivos y criterios definidos de la etapa análisis, se construirán los artefactos y componentes de la Metodología de Evaluación de Riesgos Cloud.

Construcción de Propuesta de Metodología

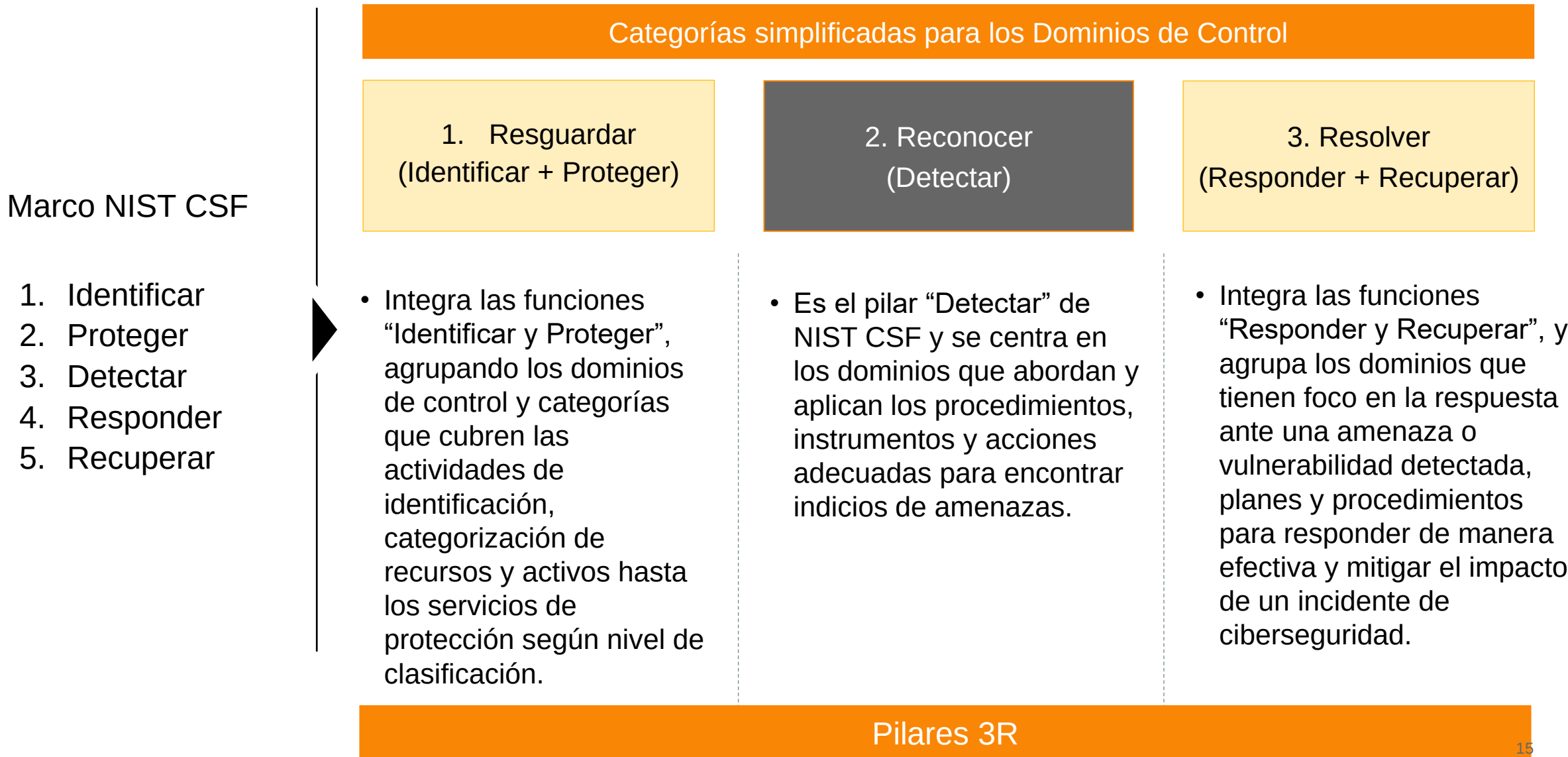


DESARROLLO Y CONSTRUCCIÓN

Objetivo: Estandarizar y simplificar los Dominios de Control para agrupar los diferentes aspectos de seguridad identificados en categorías coherentes y fáciles de entender.



ESTANDARIZACIÓN DE LOS DOMINIOS DE CONTROL



ESTANDARIZACIÓN DE LOS DOMINIOS DE CONTROL

Dominio	CSA CCM	CIS	NIST
1	Auditoría & Aseguramiento	Inventario y Control de Activos Empresariales	Control de acceso (AC)
2	Seguridad de aplicaciones e interfaces	Inventario y Control de Activos de Software	Sensibilización y Formación (AT)
3	Gestión de la continuidad del negocio y resiliencia operativa	Protección de datos	Auditoría y Rendición de Cuentas (AU)
4	Control de Cambios y Gestión de la Configuración	Configuración segura de activos y software de la empresa	Evaluación y autorización de seguridad (CA)
5	Criptografía, cifrado y gestión de claves	Gestión de cuentas	Gestión de la configuración (CM)
6	Seguridad del Centro de Datos	Gestión del control de acceso	Planes de contingencia (CP)
7	Ciclo de vida de la seguridad y privacidad de los datos	Gestión continua de vulnerabilidades	Identificación y autenticación (IA)
8	Gobierno, Gestión de Riesgos y Cumplimiento	Gestión de registros de auditoría	Respuesta a incidentes (IR)
9	Recursos Humanos	Protecciones de correo electrónico y navegador web	Mantenimiento (MA)
10	Gestión de identidades y accesos	Defensas contra malware	Protección de medios
11	Interoperabilidad y portabilidad	Recuperación de datos	Protección Física y Entorno (PE)
12	Seguridad de infraestructura y virtualización	Gestión de la infraestructura de red	Planificación (PL)
13	Registro y Monitoreo	Monitoreo y defensa de redes	Seguridad del Personal (PS)
14	Gestión de Incidentes de Seguridad, E-Discovery y Forense en nube	Capacitación en habilidades y concientización en seguridad	Evaluación de riesgos (RA)
15	Gestión de la Cadena de Suministro, Transparencia y Trazabilidad	Gestión de proveedores de servicios	Evaluación y autorización de seguridad (SA)
16	Gestión de Amenazas y Vulnerabilidades	Seguridad del software de la aplicación	Protección de sistemas y comunicaciones (SC)
17	Gestión global de dispositivos terminales ('Endpoint')	Gestión de la respuesta a incidentes	Integridad del sistema y de la información (SI)
18		Pruebas de penetración	Gestión de programas (PM)
19			Adquisición de sistemas y servicios (SA)
20			Gestión de Riesgos de la Cadena de Suministro (SR)

ESTANDARIZACIÓN DE LOS DOMINIOS DE CONTROL: DESARROLLO

Ejemplo CSA CCM			
#	Dominio	Evaluación 3R	Desarrollo y Consideraciones
1	Auditoría & Aseguramiento	(2) Reconocer	La auditoría y la garantía de la seguridad cibernética implican principalmente la capacidad de reconocer o detectar posibles amenazas, vulnerabilidades, o incidentes de seguridad en los sistemas y la infraestructura de una organización. Esto incluye actividades como monitorear y analizar registros de eventos, realizar evaluaciones de seguridad, llevar a cabo pruebas de penetración, y realizar investigaciones forenses en caso de incidentes de seguridad
2	Seguridad de aplicaciones e interfaces	(1) Resguardar	Este dominio se enfoca en implementar medidas de seguridad para proteger las aplicaciones y las interfaces de usuario contra diversas amenazas y vulnerabilidades. Implica la aplicación de controles de seguridad en el desarrollo de software, la implementación de políticas de seguridad para las interfaces de usuario, la gestión de accesos y privilegios, y la aplicación de técnicas de codificación segura
3	Gestión de la continuidad del negocio y resiliencia operativa	(3) Resolver	Este dominio se enfoca en la capacidad de una organización para responder de manera efectiva a incidentes y eventos adversos, así como en su capacidad para mantener la continuidad del negocio y la operatividad de sus sistemas frente a interrupciones. Implica la implementación de planes y procedimientos de respuesta a incidentes, así como medidas para garantizar la recuperación rápida y eficiente de los sistemas y procesos afectados.
4	Control de Cambios y Gestión de la Configuración	(1) Resguardar	Este dominio se centra en establecer y mantener controles sobre los cambios en la configuración de los sistemas y la infraestructura de tecnología de la información. Implica implementar procesos y políticas para gestionar de manera efectiva los cambios, asegurando que solo se realicen cambios autorizados y que se minimice el impacto potencial en la seguridad y la estabilidad de los sistemas.
5	Criptografía, cifrado y gestión de claves	(1) Resguardar	Este dominio se enfoca en implementar y gestionar técnicas criptográficas y sistemas de encriptación para proteger la confidencialidad, integridad y autenticidad de los datos. Implica la utilización de algoritmos de cifrado, la gestión de claves criptográficas y el aseguramiento de que la información sensible esté protegida adecuadamente mediante técnicas de cifrado.
6	Seguridad del Centro de Datos	(1) Resguardar	Este dominio se enfoca en implementar medidas de seguridad para proteger los centros de datos físicos y virtuales de una organización. Esto incluye la implementación de controles de acceso físico, medidas de seguridad ambiental, protección contra incendios y otros desastres naturales, así como la implementación de controles de seguridad de red y sistemas dentro del entorno del datacenter.

ESTANDARIZACIÓN DE LOS DOMINIOS DE CONTROL: DESARROLLO

Matriz de Dominios de Control y Pilares 3R			
Dominios de Control	Resguardar	Reconocer	Resolver
CSA CCM	(2) Seguridad de aplicaciones e interfaces	(1) Auditoría y Aseguramiento	(3) Gestión de la Continuidad del Negocio y Resiliencia Operativa
	(4) Control de cambios y gestión de la configuración	(13) Registro y monitoreo	(11) Interoperabilidad y portabilidad
	(5) Criptografía, Encriptación y Gestión de Claves	(16) Gestión de amenazas y vulnerabilidades	(14) Gestión de incidentes, e-Discovery y análisis forense
	(6) Seguridad del centro de datos		
	(7) Ciclo de vida de la seguridad y la privacidad de los datos		
	(8) Gobierno, Riesgo y Cumplimiento		
	(9) Recursos humanos		
	(10) Gestión de identidades y accesos		
	(12) Seguridad de infraestructura y virtualización		
	(15) Gestión de la cadena de suministro, transparencia y rendición de cuentas		
	(17) Gestión universal de endpoints		
CIS	(1) Inventario y Control de Activos Empresariales	(7) Gestión continua de vulnerabilidades	(11) Recuperación de datos
	(2) Inventario y Control de Activos de Software	(8) Gestión de registros de auditoría	(17) Gestión de la respuesta a incidentes
	(3) Protección de datos	(13) Monitoreo y defensa de redes	
	(4) Configuración segura de activos y software de la empresa	(17) Pruebas de penetración	
	(5) Gestión de cuentas		
	(6) Gestión del control de acceso		
	(9) Protecciones de correo electrónico y navegador web		
	(10) Defensas contra malware		
	(12) Gestión de la infraestructura de red		
	(14) Capacitación en habilidades y concientización en seguridad		
	(15) Gestión de proveedores de servicios		
	(16) Seguridad del software de la aplicación		

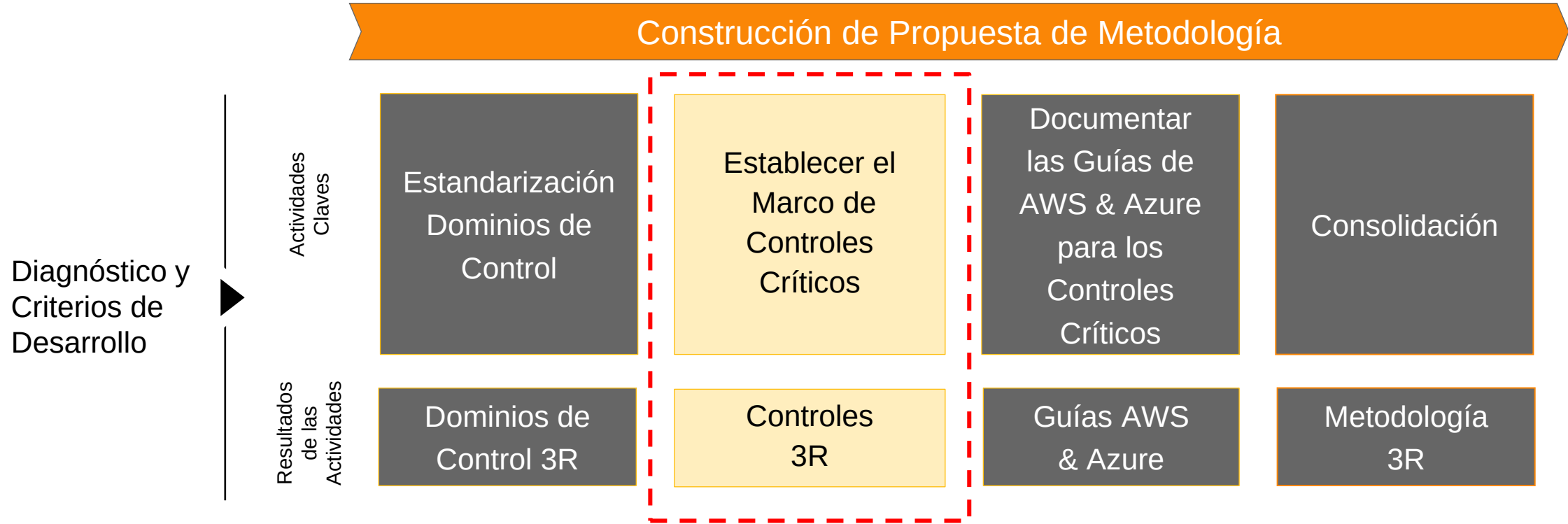
ESTANDARIZACIÓN DE LOS DOMINIOS DE CONTROL: DESARROLLO

Matriz de Dominios de Control y Pilares 3R			
Dominios de Control	Resguardar	Reconocer	Resolver
NIST	(1) Control de acceso (AC)	(3) Auditoría y Rendición de Cuentas (AU)	(6) Planes de contingencia (CP)
	(2) Sensibilización y Formación (AT)	(14) Evaluación de riesgos (RA)	(8) Respuesta a incidentes (IR)
	(4) Evaluación y autorización de seguridad (CA)	(17) Integridad del sistema y de la información (SI)	
	(5) Gestión de la configuración (CM)		
	(7) Identificación y autenticación (IA)		
	(9) Mantenimiento (MA)		
	(10) Protección de medios (MP)		
	(11) Protección Física y Entorno (PE)		
	(13) Seguridad del Personal (PS)		
	(15) Evaluación y autorización de seguridad (SA)		
	(16) Protección de sistemas y comunicaciones (SC)		
	(18) Gestión de programas (PM)		
	(19) Adquisición de sistemas y servicios (SA)		
	(20) Gestión de Riesgos de la Cadena de Suministro (SR)		

Como resultado se simplifican los Dominios de Control, agrupándolos en 3 Nuevas categorías parte de Metodología 3R: Resguardar, Reconocer y Resolver

MARCO DE CONTROLES CRÍTICOS

Establecer una base de Controles Críticos CIS, NIST y que incorporen los controles de CSA CCM Aplicables en AWS y Azure, desarrollando un nuevo benchmark consistente con los Fundamentos de Seguridad de CSA para la Evaluación de Riesgo de Cloud



MARCO DE CONTROLES CRÍTICOS

Diseño y Criterios de Selección



Como estrategia de desarrollo, para poder establecer una base de Controles Críticos y que incorporen los controles de CSA CCM, se contemplaron los siguientes criterios:

- **Fuentes:** se utilizaron los benchmarks y guías operativas con los controles que tienen en común.
 - *Atributos de Selección de benchmarks*
 - *Relevancia:* en relación con la industria, de los marcos seleccionados.
 - *Representatividad:* debe ser representativo con los controles y marcos seleccionados.
 - *Adaptabilidad:* se debe adaptar a los objetivos definidos (incorporar CSA CCM).
- **Relación de los Controles:** la Matriz de Controles de CSA CCM contiene un mapa de la relación entre sus controles y sus referencias de CIS y NIST. Esto es fundamental ya que permitirá correlacionarlos con los benchmarks que se consideran como fuente en la construcción y posteriormente con la documentación de las guías de configuración de AWS y Azure.
- **Pilares 3R:** En la clasificación de los controles identificados se incorporarán los Pilares 3R ya que esto permite mapear los controles con Dominios que ya se han simplificado.

MARCO DE CONTROLES CRÍTICOS

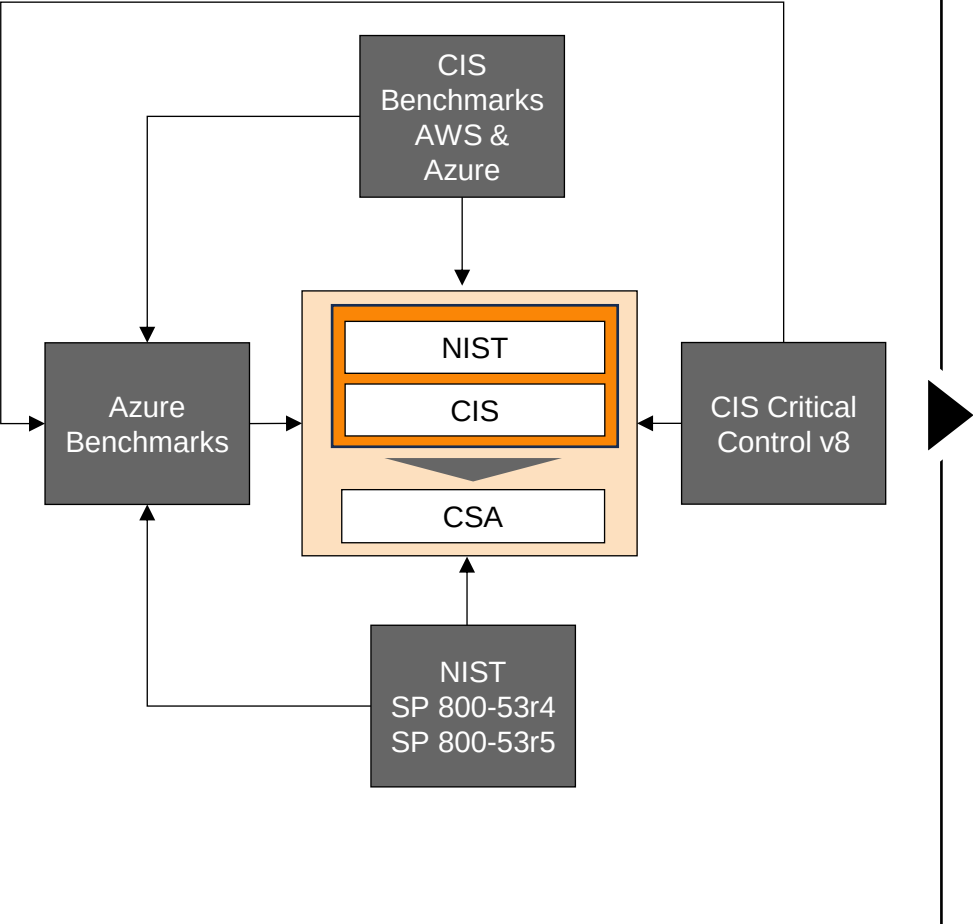
Evaluación de los Criterios de Selección



Atributos /Benchmarks	Azure Security Benchmark	CIS Benchmarks AWS & Azure	Guías Operativas AWS
Relevancia <i>Considerando al Center for Internet Security (CIS) como un líder en la publicación de benchmarks y guías de seguridad.</i>	Se encuentra publicado como benchmark de la industria en el Center for Internet Security (CIS)	Se encuentra publicado como benchmark de la industria en el Center for Internet Security (CIS)	No existe una publicación de benchmark desarrollado desde AWS en el Center for Internet Security (CIS)
Representatividad <i>Considerando el enfoque de desarrollo en los Marcos de Control</i>	Está desarrollado con un enfoque que ya incluye los marcos: • CIS Controls v8 • NIST SP 800-53 r4 • PCI-DSS v3.2.1	Está desarrollado con un enfoque que incluye los marcos: • CIS Controls v8	Existen guías operativas que permiten implementar los controles sugeridos desde los Marcos de referencias.
Adaptabilidad <i>Considerando como se adaptan al objetivo</i>	Se adapta incorporando controles que ya incluye los marcos CIS y NIST de forma integrada.	Se adapta incorporando controles que incluye el marco de control CIS.	Las guías operativas permiten adaptar los controles de forma independiente.

ESTABLECER EL MARCO DE CONTROLES CRÍTICOS

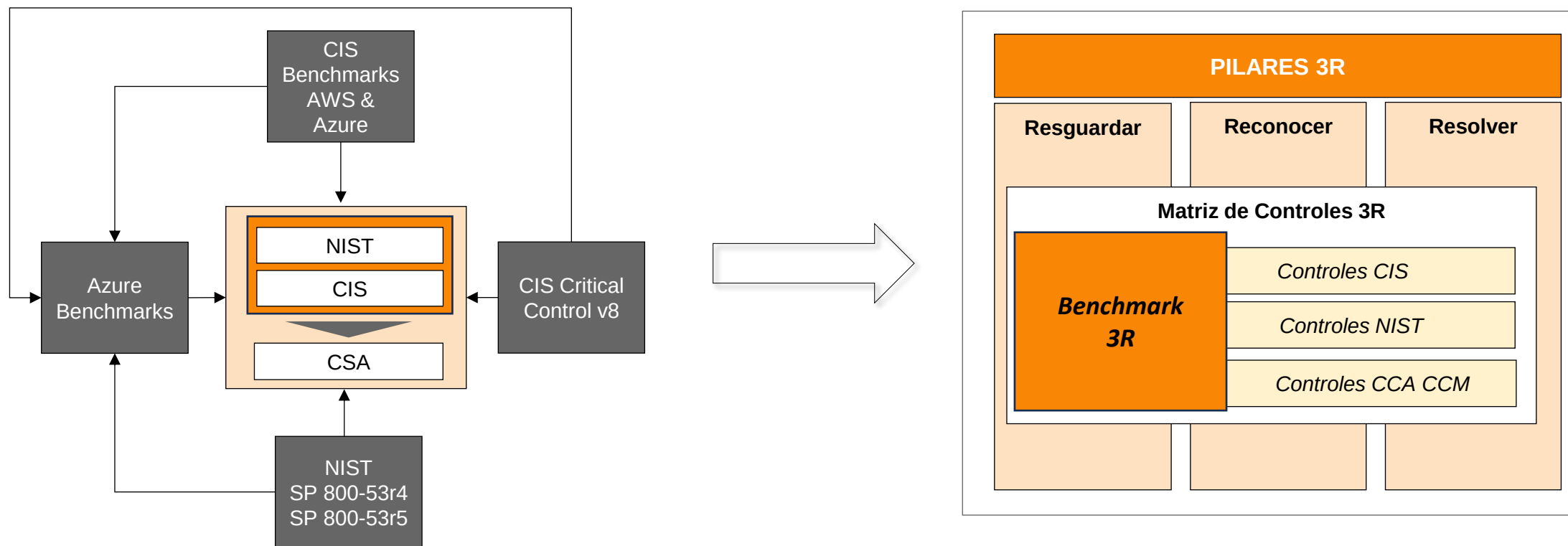
Construcción de la Matriz de Controles 3R



Actividad	Tareas
1. Establecer Controles Críticos de base 3R	- Establecer y Documentar la base de controles, que a partir de ahora llamaremos “Controles Críticos 3R,” desde los benchmarks: Azure Security Benchmark. - La base inicial contiene 85 dimensiones de evaluación que abarcan 104 controles CIS divididos en 12 categorías.
2. Integración del Marco de control NIST SP 800-53r5	- Análisis y actualización de Controles a SP 800-53r5. - Se incorporan y actualizan en total 50 controles de seguridad del NIST SP 800-53r5 que cubren severidad crítica y moderada.
3. Integración CIS Controls v8 y benchmark AWS	Análisis de GAP, se actualizan controles de seguridad.
4. Integración del Marco de Control CSA CCM	- Análisis de los controles CIS/NIST, sus objetivos y principios de seguridad. - Se seleccionan 133 Controles CSA CCM que están mapeados a los controles CIS y NIST de la base.
5. Establecer los Dominios 3R para los controles	Análisis y documentación de los dominios de control 3R y su relación con los controles críticos.

ESTABLECER EL MARCO DE CONTROLES CRÍTICOS

Construcción de la Matriz de Controles 3R



Como resultado de la construcción, la Matriz Controles 3R contiene:

- 3 pilares funcionales 3R: Resguardar, Reconocer y Resolver.
- 85 dimensiones de control (Familias o Dominios), agrupadas en 12 categorías o subdominios.
- Estas dimensiones de evaluación consolidan e integran en:
 - 104 controles CIS / 50 controles NIST / 133 controles CSA CCM

ESTABLECER EL MARCO DE CONTROLES CRÍTICOS

Construcción de la Matriz de Controles 3R



Dominio 3R	Subdominio Funcional	Control CSA CCM v4	Control CIS v8	Control NIST SP800-53 r5	Objetivo	Directrices
Resguardar	Gestión de activos	DCS-05 Clasificación de Activos DCS-06 Catalogación y seguimiento de activos UEM-04 Inventario de terminales (Endpoints)	1.1 - Establecer y mantener un inventario detallado de activos empresariales 1.5 - Utilice una herramienta de descubrimiento de activos pasivos 2.1 - Establecer y mantener un inventario de software 2.4 - Utilice herramientas de inventario de software automatizadas	CM-8 Inventario de componentes del sistema PM-5 Inventario del sistema	Control de inventario de activos y riesgos	Encuentre todos sus recursos en la nube y realice un seguimiento de su inventario de activos a través de consultas. Etiquete y clasifique sus activos según su ubicación, tipo de servicio y otros atributos para organizarlos de forma lógica. Asegúrese de que el inventario de activos de su organización de seguridad se actualiza periódicamente Al mantener la información y los riesgos de seguridad consolidados de forma centralizada, puede asegurarse de que su equipo de seguridad pueda vigilar las amenazas que plantean los activos en la nube.

El resultado es la Matriz Controles Críticos 3R se encuentra en el **Anexo : Matriz Controles Críticos 3R.**

GUÍAS DE ADOPCIÓN AWS & AZURE

Objetivos

Estas guías tienen como objetivo facilitar la implementación de los controles de seguridad, proporcionando información sobre cómo navegar, configurar los servicios y aplicar las mejores prácticas

Construcción de Propuesta de Metodología

Diagnóstico y
Criterios de
Desarrollo

Actividades
Claves

Resultados
de las
Actividades

Estandarización
Dominios de
Control

Establecer el
Marco de
Controles
Críticos

Documentar
las Guías de
AWS & Azure
para los
Controles
Críticos

Consolidación

Dominios de
Control 3R

Controles
3R

Guías AWS
& Azure

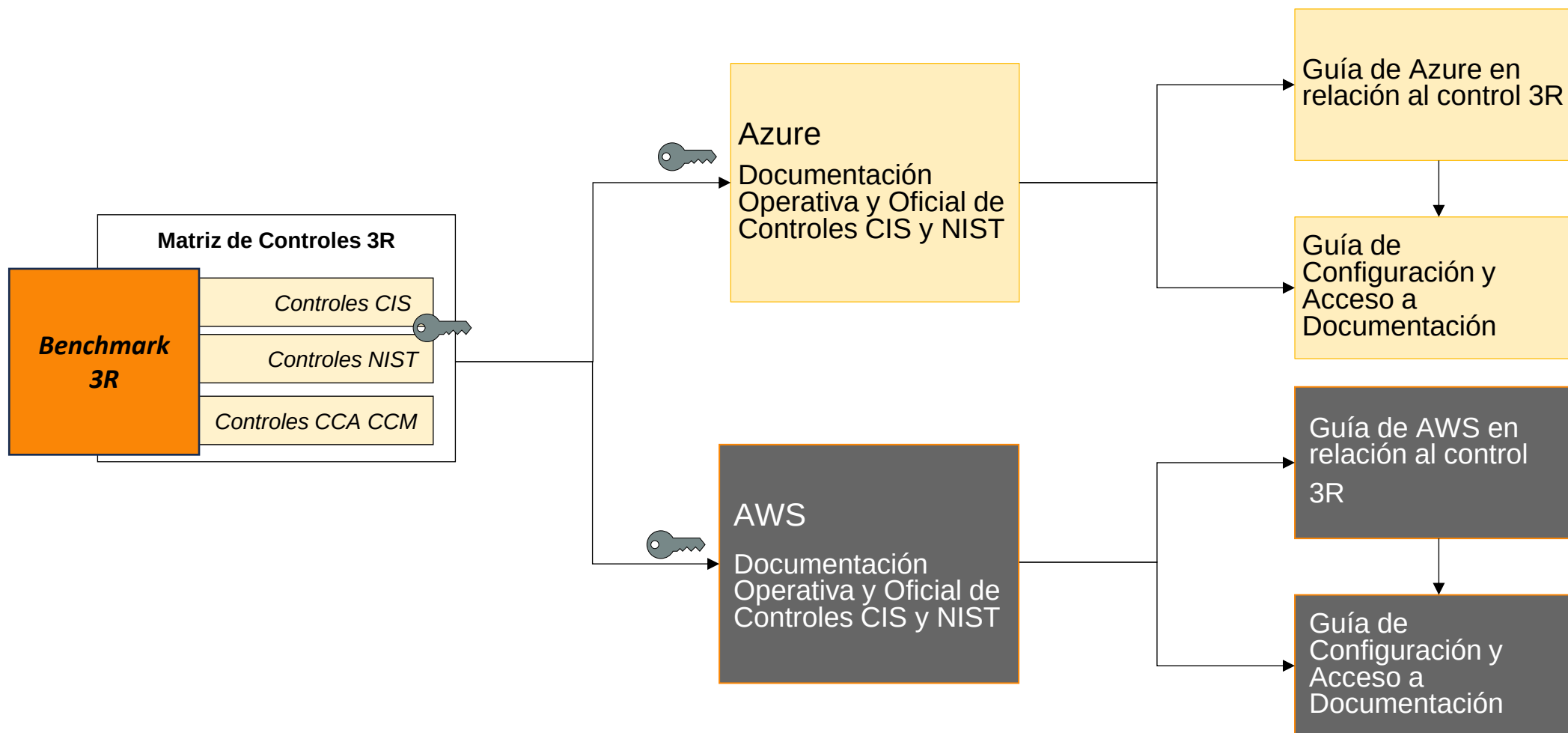
Metodología
3R

GUÍAS DE ADOPCIÓN AWS & AZURE

Relación de los Controles y la Documentación

Evaluación y Relacionamiento

Construcción y Documentación de Guía

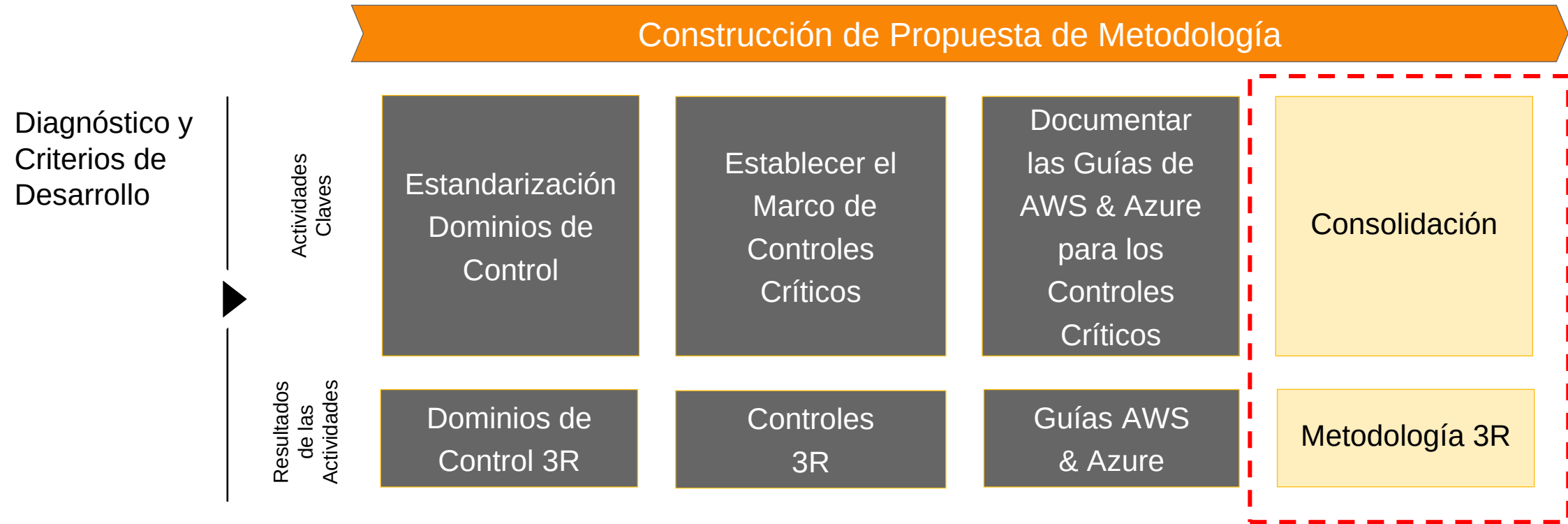


GUÍAS DE ADOPCIÓN AWS & AZURE

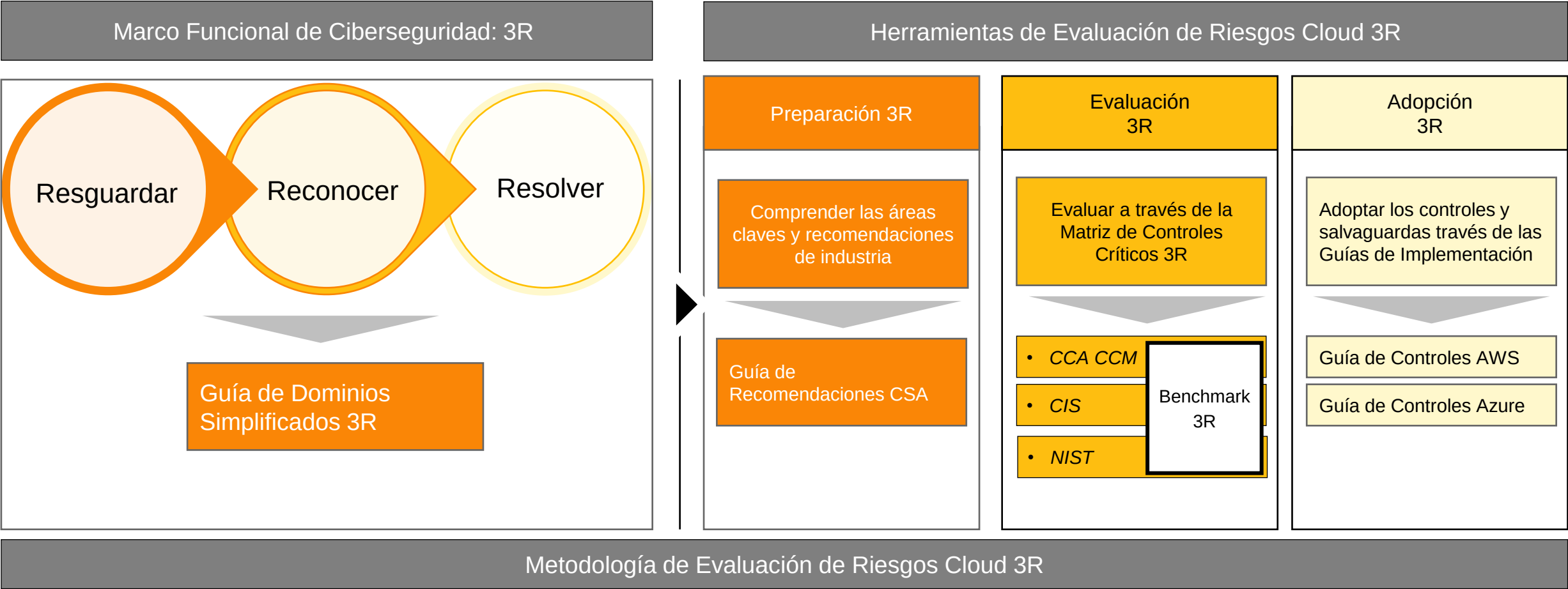
Relación de los Controles y la Documentación

Control 3R	Guía Azure (Ejemplo)	Navegación y Recursos de Configuración
Control CSA CCM v4 - DCS-05 Clasificación de Activos - DCS-06 Catalogación y seguimiento de activos - UEM-04 Inventario de terminales (Endpoints) CIS ControlsV8 1.1 - Establecer y mantener un inventario detallado de activos empresariales 1.5 - Utilice una herramienta de descubrimiento de activos pasivos 2.1 - Establecer y mantener un inventario de software 2.4 - Utilice herramientas de inventario de software automatizadas NIST SP800-53 r5 - CM-8 Inventario de componentes del sistema - PM-5 Inventario del sistema	La característica de inventario de Microsoft Defender for Cloud y Azure Resource Graph se pueden consultar y detectar todos los recursos de las suscripciones, incluidos los servicios, las aplicaciones y los recursos de red de Azure. Organizar lógicamente los recursos según la taxonomía de su organización mediante etiquetas y otros metadatos de Azure (nombre, descripción y categoría). Asegurar de que las organizaciones de seguridad tengan acceso a un inventario de recursos en Azure que se actualiza continuamente. Los equipos de seguridad a menudo necesitan este inventario para evaluar la exposición potencial de su organización a los riesgos emergentes y como insumo para las mejoras continuas de seguridad. Asegurar de que las organizaciones de seguridad tienen permisos de lector de seguridad en el inquilino y las suscripciones de Azure para que puedan supervisar los riesgos de seguridad mediante Microsoft Defender for Cloud. Los permisos de lector de seguridad se pueden aplicar ampliamente a todo un inquilino (grupo de administración raíz) o en el ámbito de grupos de administración o suscripciones específicas. Nota: Es posible que se requieran permisos adicionales para obtener visibilidad de las cargas de trabajo y los servicios.	Creación de consultas con el Explorador de Azure Resource Graph: https://docs.microsoft.com/azure/governance/resource-graph/first-query-portal Administración del inventario de recursos de Microsoft Defender for Cloud: https://docs.microsoft.com/azure/security-center/asset-inventory Para obtener más información sobre el etiquetado de recursos, consulte la guía de decisión de nomenclatura y etiquetado de recursos: https://docs.microsoft.com/azure/cloud-adoption-framework/decision-guides/resource-tagging/?toc=/azure/azure-resource-manager/management/toc.json Información general sobre la función de lector de seguridad: https://docs.microsoft.com/azure/role-based-access-control/built-in-roles#security-reader

CONSOLIDACIÓN DE LA METODOLOGÍA



CONSOLIDACIÓN DE LA METODOLOGÍA



CONCLUSIONES Y CIERRE

- El estudio y trabajo realizado proporcionaron una comprensión clara de los fundamentos de Seguridad en la Nube, lo que permitió una comprensión más profunda, de los aspectos relevantes, y de las consideraciones específicas sobre servicios en la nube, conectando conceptos teóricos y técnicos en la función de los marcos, prácticas y tecnología evaluada.
- Como parte del proceso de construcción, se diseñó, desarrollaron métodos y artefactos para integrar las prácticas, las oportunidades identificadas entre estas y las tecnologías seleccionadas en la metodología de evaluación de riesgos 3R, que como resultado puede complementar las operaciones de ciberseguridad existentes o servir como base para nuevos programas.
- Conectando los objetivos iniciales del Trabajo de Fin de Master, podemos concluir que se ha desarrollado una metodología aplicable para mejorar la seguridad y la gestión de riesgos en los entornos de nube, proporcionando un marco simplificado para la evaluación y la mitigación de riesgos, protegiendo así las actividades y datos organizacionales en un entorno digitalizado y en evolución.

Preguntas & Respuestas

Muchas gracias



Universidad
Internacional
de Valencia